

Static Malware Analysis

Static vs Dynamic

Static – analyze the file WITHOUT executing it (safe)

Dynamic – run it in a sandbox and observe (dangerous, but revealing)

Start static; move to dynamic (in a VM) when needed.

The Static Toolkit

```
file sample.bin           # what type of file is it?
sha256sum sample.bin      # hash → look up in VT
strings -n 6 sample.bin   # printable strings (URLs, paths, creds)
exiftool sample.exe       # metadata
```

Hashing first. Query VirusTotal / MalwareBazaar by hash – the answer may already be public. The hash is the file's DNA.

Files Insight

```
file notepad.exe # PE32+ executable (GUI) x86-64, for MS Windows
```

PE32 = 32-bit, **PE32+** = 64-bit

ELF = Linux

Mach-O = macOS

MZ header = DOS/Windows executable

Strings Analysis

```
strings -n 7 sample.exe |less
strings -n 7 sample.exe |grep -iE "http|cmd|powershell|reg|vbs|mail"
```

Strings reveal:

URLs / C2 hostnames

Hardcoded passwords / keys

File paths (persistence)

Encryption keys

If nothing readable → **packed/obfuscated** (huge red flag)

PE Structure (Windows Executables)

DOS header — **MZ**

PE header — signature, machine type

Sections — .text (code), .data, .rdata, .rsrc

Imports — functions from DLLs (the "shopping list": **CreateFile**, **WinHttp** ...)

Exports — functions it offers

Import analysis alone identifies capability: **WinHttp** + **crypt** + **CreateProcess** = a network-aware downloader that runs things.

YARA: The Signature Language

YARA matches byte patterns / strings / regex on files:

```
rule Evil_Family
{
  meta:
    description = "Detects Evil_Family markers"
  strings:
    $s1 = "EvilUniqueURL" nocase
    $s2 = { E8 ?? ?? ?? ?? 74 ?? 51 }
  condition:
    uint16(0) == 0x5A4D and 2 of them
}
```

Analysts (and EDRs) write YARA rules to catch families. You'll write, test, and share YARA rules in SOC work.

Static Analysis Doesn't Lie Obfuscated

Heavily obfuscated samples may defeat strings. Then you:

Check **entropy** (high = packed/encrypted)

Run a **unpacker** (UPX often)

Move to **dynamic** (sandbox)

Or analyze the LOADER vs the PAYLOAD (two-stage)

[← Malware Types & Capabilities](#)

[Dynamic Analysis & Sandboxing →](#)